

TP FIL ROUGE : 3 HEURES

Mission Paynora

Classer, protéger et gouverner les actifs d'une fintech de paiement

Lucas Vitrant, Louis Vanlaer, Hajar El Abid

GROUPE C

Cadre	Modalités
Organisation	Groupes de 3 à 4 étudiants
Durée	3 h
Production attendue	Un dossier de réponse de 5 à 8 pages + les matrices complétées
Posture	Vous êtes l'équipe de conseil mandatée par la direction générale

Votre mission : Proposer un dispositif cohérent de classification, de protection et de gouvernance. Chaque choix doit être justifié par la valeur métier et les risques, jamais uniquement par la technologie.

Compétences travaillées

- Inventorier les actifs et attribuer leur propriété.
- Évaluer confidentialité, intégrité et disponibilité séparément.
- Définir une classification et une baseline de contrôles proportionnée.
- Adapter la protection aux états At Rest, In Transit et In Process.
- Organiser rétention, archivage et destruction défendable.
- Distinguer gouvernance stratégique, pilotage tactique et mise en œuvre opérationnelle.

Déroulé conseillé

Temps	Phase	Résultat
0:00 à 0:20	Prise de connaissance et rôles	Compréhension commune du cas
0:20 à 1:10	Inventaire et classification	Matrice C-I-D complétée
1:10 à 2:00	Protection et cycle de vie	Règles de manipulation et contrôles
2:00 à 2:40	Gouvernance	RACI simplifié et décisions prioritaires
2:40 à 3:00	Arbitrage et finalisation du dossier	Plan d'action priorisé et synthèse

DOSSIER DE MISSION

Paynora sous pression : une croissance rapide, des flux financiers sensibles et des responsabilités mal définies

b

1. L'entreprise

Paynora est une PME française de 92 salariés. Elle édite PayFlow, une plateforme de paiement utilisée par 3 800 e-commerçants pour encaisser leurs clients, gérer les remboursements et détecter la fraude grâce à un moteur d'IA. L'entreprise vise une expansion européenne dans six mois et prépare une levée de fonds.

La direction générale veut accélérer la migration vers le cloud. La DSI pilote aujourd'hui presque tous les sujets de données, mais aucun inventaire formel n'existe. Plusieurs directions pensent que la DSI est automatiquement propriétaire des actifs hébergés sur ses systèmes.

2. Les événements déclencheurs

- Un chargé de comptes a envoyé à son adresse personnelle un export de 2 600 marchands prospects afin de travailler le week-end.
- Un administrateur a supprimé par erreur des journaux de transactions vieux de quatre mois. Aucune durée de conservation n'était définie.
- Un ordinateur portable non chiffré contenant des documents RH temporaires a été oublié dans un TGV.
- Le prestataire cloud indique qu'il ne garantit pas la destruction physique individualisée des SSD.
- Pendant une mise à jour, PayFlow a été indisponible pendant trois heures. Plusieurs e-commerçants n'ont pas pu encaisser en plein pic de ventes.
- Les développeurs utilisent parfois un extrait pseudonymisé de la base de transactions pour tester une nouvelle version.

3. Contraintes de direction

- Le budget sécurité supplémentaire est limité à 120 000 € sur douze mois.
- La plateforme doit rester disponible pendant la migration.
- Les mesures ne doivent pas bloquer les encaissements ni les remboursements urgents.
- La direction veut des décisions compréhensibles par des non-techniciens.
- Les données doivent rester hébergées dans l'Union européenne.

Point de vigilance : une mesure très forte n'est pas automatiquement une bonne mesure : elle doit être adaptée à la valeur de l'actif, à son état et aux besoins métiers.

TRAVAIL DEMANDÉ

Six livrables : une analyse structurée à remettre au comité de direction

Livrable 1 : Système de classification

- **Proposez quatre niveaux de classification, du moins sensible au plus sensible. Donnez pour chaque niveau une définition et deux exemples de règles obligatoires.**

1. Système de classification des données

Ce système permet de catégoriser les informations et les actifs de Paynora selon leur niveau de sensibilité afin d'appliquer les mesures de sécurité adaptées.

Niveau N1 : Public

- Définition : Il s'agit des informations destinées à être diffusées au grand public. Une fuite ou une divulgation de ces données ne cause aucun dommage significatif pour l'entreprise.
- Règles obligatoires :
 - La publication doit obligatoirement se faire depuis un espace formellement validé.
 - L'intégrité de l'information doit être garantie par l'utilisation d'une version officielle et la désignation d'un responsable clairement identifié.

Niveau N2 : Interne

- Définition : Ce sont les informations relatives au fonctionnement interne qui ne sont pas publiques. Si elles venaient à être divulguées, l'impact resterait limité.
- Règles obligatoires :
 - L'accès est strictement réservé aux comptes Paynora dûment authentifiés.
 - Le partage vers l'extérieur ou vers des adresses mails personnelles est totalement interdit sans autorisation préalable.

Niveau N3 : Confidentiel

- Définition : Cela regroupe les données métiers sensibles, contractuelles ou personnelles. Une fuite ou une altération de ces données aurait un impact important sur l'entreprise.
- Règles obligatoires :
 - Le chiffrement est obligatoire, aussi bien au repos (stockage) qu'en transit (transfert), combiné au principe du besoin d'en connaître (accès limité aux personnes qui en ont strictement besoin).
 - Tout export ou partage externe doit être journalisé et soumis soit à un contrôle DLP (Data Loss Prevention), soit à une validation préalable.

Niveau N4 : Critique

- Définition : Il s'agit des actifs dont la compromission peut affecter une activité essentielle de l'entreprise, des obligations légales majeures, des personnes, ou directement la capacité de Paynora à opérer.
- Règles obligatoires :
 - Authentification multifacteur (MFA) et principe du moindre privilège requis, associés à une traçabilité renforcée.

- Application d'un chiffrement fort, procédures de sauvegarde et de restauration régulièrement testées, et interdiction absolue de copier ces données sur un équipement non géré par l'entreprise.

- **Expliquez en 5 lignes pourquoi la classification doit être revue dans le temps.**

Une classification n'est pas figée : le contenu, l'usage, le volume et les réglementations changent, ce qui peut vite la rendre fausse. Une revue est donc obligatoire au moins une fois par an. Elle doit aussi se faire lors de cas spécifiques : migration cloud, nouvel usage, incident, changement de propriétaire ou évolution contractuelle/réglementaire.

- Responsabilités : Le propriétaire métier reste responsable (imputable) du choix de la classe ; le RSSI contrôle la cohérence globale.
- Ajustements : Si la sensibilité augmente, les contrôles de sécurité doivent être immédiatement mis à niveau. Si la classe baisse, la décision doit être strictement justifiée et tracée.

Livrable 2 : Matrice C-I-D

- Pour chacun des 12 actifs, notez séparément Confidentialité, Intégrité et Disponibilité de 1 (faible) à 4 (critique).
- Attribuez un niveau global de classification et justifiez au moins six décisions, dont deux cas où l'axe le plus critique n'est pas la confidentialité.

ANNEXE B : MATRICES DE RÉPONSE

ID	Actif	C	I	D	Classe globale	Justification courte
A1	Données de paiement clients	4	4	4	N4 - Critique	Données financières et personnelles et transactions : fuite, altération ou indisponibilité ont un impact majeur.
A2	Application web PayFlow	3	4	4	N4 - Critique	
A3	Clés de chiffrement	4	4	3	N4 - Critique	La compromission des clés annule la protection des bases et sauvegardes : intégrité des clés essentielle.
A4	Sauvegardes transactions	4	4	3	N4 - Critique	Copie complète de données sensibles : une sauvegarde altérée ou inutilisable compromet la reprise.
A5	Journaux d'audit	3	4	4	N4 - Critique	L'axe dominant est l'intégrité : des logs modifiables ou supprimés rendent l'audit et l'investigation non fiables.
A6	Code source	3	4	4	N4 - Critique	Altération du code ou des scripts peut introduire une fraude ou une panne, confidentialité de l'IP importante.
A7	Données RH	4	3	2	N4 - Critique	Paie, évaluations et arrêts maladie : forte sensibilité pour les personnes et risque juridique.
A8	Base prospects marchands	3	2	2	N3 - Confidentiel	
A9	Ordinateurs portables	3	3	3	N3 - Confidentiel	
A10	Documents marketing	1	2	2	N2 - Interne	
A11	Contrats marchands et bancaires	3	4	3	N4 - Critique	
A12	Modèle IA anti-fraude	4	4	3	N4 - Critique	

- **Signalez les informations manquantes qui pourraient changer votre décision.**
 - Périmètre exact des données carte/tokenisation et exigences contractuelles ou de conformité associées.
 - SLA, RTO et RPO promis aux e-commerçants : ils peuvent faire passer certaines disponibilités de 3 à 4.
 - Durées légales/contractuelles de conservation des transactions, logs, contrats et données RH.
 - Contenu réellement stocké localement sur les portables et possibilité de synchronisation hors ligne.

- Architecture de haute disponibilité, fréquence des sauvegardes et tests de restauration actuels.
- Droits d'accès réels au CRM, au dépôt Git, au KMS et au modèle IA, y compris prestataires et comptes techniques.

ANNEXE A : INVENTAIRE INITIAL

ID	Actif	Contenu / finalité	Support	Propriétaire proposé
A1	Données de paiement clients	Identités, IBAN, cartes tokenisées, historiques de transactions	Base PostgreSQL, cloud UE	Direction des opérations
A2	Application web PayFlow	Portail d'encaissement des e-commerçants et de leurs clients	Cloud public	Direction produit
A3	Clés de chiffrement	Clés protégeant les bases et sauvegardes	Service KMS cloud	RSSI
A4	Sauvegardes transactions	Copie quotidienne chiffrée de la base de paiement	Stockage objet cloud	DSI
A5	Journaux d'audit	Connexions, opérations de paiement et modifications	SIEM + stockage cloud	RSSI
A6	Code source	Code de PayFlow et scripts de déploiement	Dépôt Git privé	Direction technique
A7	Données RH	Contrats, paie, évaluations, arrêts maladie	SaaS RH	DRH
A8	Base prospects marchands	Contacts professionnels et historique commercial	CRM SaaS	Direction commerciale
A9	Ordinateurs portables	Postes des salariés, dont analystes fraude	Locaux / mobilité	DSI
A10	Documents marketing	Supports publics, charte graphique et visuels	Drive collaboratif	Marketing
A11	Contrats marchands et bancaires	Clauses, commissions, engagements et contacts	GED cloud	Direction juridique
A12	Modèle IA anti-fraude	Modèle propriétaire et paramètres entraînés	Cloud IA	Direction produit

Barème C-I-D à utiliser

Note	Interprétation	Impact indicatif
1	Faible	Gêne limitée, facilement réversible
2	Modéré	Perturbation locale ou coût maîtrisable
3	Élevé	Impact métier, juridique ou réputationnel important
4	Critique	Menace pour les personnes, la survie, les obligations majeures ou une activité essentielle

Livrable 3 : Propriété et responsabilités

- **Validez ou corrigez le propriétaire proposé dans l'inventaire.**

Le titulaire de l'actif est la direction qui va décider de son usage, de sa classification et la désignation des personnes à qui donner accès, ainsi que de la prise de risque à encadrer. Il ne s'agit donc pas nécessairement de la DSI qui n'est pas, par le fait qu'une donnée soit conservée sur un serveur ou dans le cloud, l'actuelle propriétaire juridique de l'actif d'évaluation.

Le dépositaire technique est l'équipe qui héberge, administre ou protège l'actif quotidiennement. Il exécute les décisions du propriétaire : gestion des accès, chiffrement, sauvegardes, maintenances logicielles, journalisation, destruction des données et des applications. Si un prestataire est choisi comme SaaS ou Cloud, un responsable interne Paynora doit être désigné pour piloter et contrôler la réalisation des services contractuels de cette équipe de la bonne exécution du prestataire.

- **Désignez le dépositaire technique lorsque cela est pertinent.**

Le dépositaire technique est l'équipe chargée d'héberger, d'administrer et de protéger l'actif au quotidien.

- A1 – Données de paiement clients : la DSI et l'équipe chargée des bases de données.
- A2 – Application web PayFlow : la direction technique et l'équipe DevOps.
- A3 – Clés de chiffrement : les administrateurs DSI du service KMS cloud.
- A4 – Sauvegardes des transactions : la DSI et l'équipe chargée des sauvegardes.
- A5 – Journaux d'audit : l'équipe SOC et les administrateurs du SIEM.
- A6 – Code source : l'équipe DevOps et les administrateurs du dépôt Git.
- A7 – Données RH : la DSI et l'administrateur du logiciel SaaS RH.
- A8 – Base prospects marchands : l'administrateur du CRM, rattaché à la DSI.
- A9 – Ordinateurs portables : l'équipe support informatique chargée de la gestion du parc.
- A10 – Documents marketing : la DSI et l'administrateur du drive collaboratif.
- A11 – Contrats marchands et bancaires : la DSI et l'administrateur de la GED cloud.
- A12 – Modèle IA anti-fraude : l'équipe Data/ML et l'équipe chargée de la plateforme cloud IA.

Même lorsqu'un prestataire cloud ou SaaS intervient, Paynora doit conserver un dépositaire technique interne chargé de contrôler le prestataire et de vérifier que les mesures de sécurité sont correctement appliquées.

- **Expliquez la différence entre imputabilité (accountability) et responsabilité opérationnelle.**

Le terme imputabilité, ou accountability, indique que, pour un bien, une personne ou un organe doit répondre des choix effectués. Le propriétaire est imputable : il valide la classification, les droits d'accès au bien, le mode de conservation, le traitement du risque alentour. Il peut déléguer des tâches, mais il ne peut pas déléguer l'obligation de rendre compte à la direction générale de ses décisions.

La responsabilité opérationnelle correspond à la mise en œuvre concrète de ces décisions. Le gardien technique gère la configuration de l'ensemble des droits, la mise en œuvre des sauvegardes, le chiffrement, l'installation des mises à jour ou la production de la preuve de destruction. Il engage sa responsabilité sur la bonne exécution de ses tâches, mais il ne décide pas seul des besoins métiers.

Pour prendre un exemple concret, lorsque la direction des opérations fixe avec les services

concernés les durées de conservation et de disponibilité des sauvegardes des transactions A4, elle engage son imputabilité ; la DSI assume, elle, la responsabilité opérationnelle de la sauvegarde et des tests de restauration. Si le stockage est délégué à un prestataire cloud, Paynora reste responsable de la maîtrise de ses données et doit au préalable.

Livrable 4 : Protection et cycle de vie

- **Sélectionnez six actifs prioritaires. Pour chacun, proposez des contrôles adaptés aux états At Rest, In Transit et In Process.**

Contrôles et cycle de vie : six actifs prioritaires

Actif	At Rest	In Transit	In Process	Rétention	Destruction
Données de paiement clients	Chiffrement DB, tokenisation, accès restreint	Flux chiffrés, aucun export en clair	Comptes dédiés, données masquées en hors-prod	5 ans (obligations légales et fiscales)	Suppression logique + crypto-effacement des clés cloud
Application web PayFlow	Secrets hors du code, images signées	HTTPS/TLS pour tous les flux	WAF (pare-feu web), contrôle des entrées	24 mois pour les versions/logs de release	Suppression des images et secrets obsolètes
Clés de chiffrement	Gestion via KMS, clés non exportables	Jamais de clé brute par mail/fichier	Moindre privilège, traçabilité totale des accès	Durée de vie égale aux données à déchiffrer	données à déchiffrer Crypto-shredding
Sauvegardes transactions	Chiffrement, stockage immuable	Canal chiffré entre base de données et stockage	Tests de restauration en milieu isolé	35 jours (quotidiennes) + 12 mois (mensuelles)	Expiration automatique + crypto-effacement cloud
Journaux d'audit	Stockage en écriture seule, horodatage	TLS vers le serveur SIEM, agents authentifiés	Alertes sur modification /suppression de logs	12 mois accessibles + 12 mois archivés	Purge automatique tracée + crypto-effacement cloud
Ordinateurs portables	Chiffrement de disque complet	VPN obligatoire, blocage des transferts perso	MFA obligatoire, pas de données stockées en local	30 jours max pour les fichiers locaux temporaires	Remote wipe ou destruction physique certifiée

- **Définissez une règle de rétention et une méthode de destruction. Traitez explicitement le cas des SSD cloud.**

Concernant la règle de rétention, les durées de conservation sont appliquées en fonction de la typologie des données : les données de paiement et de transaction sont conservées pendant 5 ans afin de répondre aux obligations légales et fiscales, les journaux d'audit sont conservés durant 1 an, et les documents RH temporaires sont supprimés dès le départ du collaborateur.

S'agissant de la méthode de destruction, l'exigence d'une destruction physique des disques SSD est irréaliste dans un environnement cloud mutualisé. La solution retenue est le crypto-effacement, qui consiste à détruire définitivement la clé de chiffrement gérée via le KMS de l'entreprise, rendant ainsi la donnée totalement inexploitable. Ce procédé est complété par une suppression logique des accès, l'obtention d'une attestation d'effacement auprès du fournisseur cloud, ainsi que l'acceptation formelle du risque résiduel par la direction.

- **Proposez une règle d'étiquetage ou de marquage utile et proportionnée.**

On applique une règle de marquage basée sur nos 4 niveaux de sécurité (public, interne, confidentiel, critique). Dans les fichiers bureautiques, le niveau de sécurité est inscrit dans les propriétés du document. Pour le sensible (N3/N4), on ajoute un bandeau visuel (confidentiel ou critique) en haut ou bas de page, qui se propage dans l'objet des e-mails pour permettre au système de bloquer l'envoi vers des adresses perso. Pour les bases de données et APIs, on utilise un tag technique dans le code. Enfin, tout export de données est enregistré dans les logs, et l'export du niveau N4 vers l'extérieur est strictement bloqué.

Livrable 5 : Gouvernance

- **Répartissez les décisions et actions entre niveau stratégique, tactique et opérationnel.**

Stratégique :

- Acteurs principaux : Direction Générale
- Décisions et actions : La Direction Générale approuve la politique de sécurité et définit l'appétence au risque de l'entreprise. Elle valide également le budget alloué à la cybersécurité, les contraintes majeures comme l'hébergement des données dans l'Union européenne, les objectifs globaux de disponibilité de PayFlow ainsi que l'acceptation des risques ou exceptions les plus importantes.

Tactique :

- Acteurs principaux : RSSI, propriétaires métier et DSI
- Décisions / actions : Le niveau tactique traduit les orientations de la Direction Générale en règles applicables. Il définit la méthode de classification des actifs, les contrôles de sécurité de référence, les règles de rétention, les modalités de revue de la classification et le traitement des risques. Il précise également les exigences de sécurité à imposer aux prestataires et fournisseurs.

Opérationnel :

- Acteurs principaux : DSI, dépositaires techniques et équipes techniques
- Décisions / actions : Le niveau opérationnel met en œuvre concrètement les mesures définies aux niveaux stratégique et tactique. Il configure les mécanismes IAM, KMS et SIEM, réalise les sauvegardes, assure la supervision, applique les droits d'accès, effectue les mises à jour, les restaurations et les opérations de destruction des données.

- **Construisez un RACI simplifié pour : définir la politique, classier un actif, implémenter les contrôles, accorder un accès, revoir la classification et valider la destruction.**

ANNEXE C : GOUVERNANCE ET DÉCISION

Activité	DG	RSSI	DSI	Propriétaire métier	Dépositaire
Définir la politique	A	R	C	C	I
Classier un actif	I	C	C	A/R	C
Implémenter les contrôles	I	C	A	C	R
Accorder un accès	I	C	C	A	R
Revoir la classification	I	C	C	A/R	C
Valider la destruction	I	C	C	A	R

Lecture : A = imputable, R = réalise, C = consulté, I = informé.

- **Identifiez trois décisions qui exigent le soutien explicite de la direction.**
 1. Politique et propriétaires : officialiser que la DSI n'est pas propriétaire par défaut et rendre les propriétaires métier imputables de la classe, des accès et de la rétention.
 2. Niveau de résilience : valider le budget et les objectifs RTO/RPO/SLA de PayFlow pendant et après la migration cloud.
 3. Risques résiduels cloud : accepter ou refuser explicitement le modèle d'effacement SSD mutualisé, ainsi que les autres exceptions où le coût d'un contrôle dépasse le bénéfice métier.

Livrable 6 : Arbitrage et plan d'action

- **Priorisez cinq actions sur douze mois en respectant le budget. Classez-les P1, P2 ou P3 et expliquez le risque accepté pour ce qui est différé.**

Plan d'action sur douze mois

Priorité	Action	Responsable	Échéance	Coût estimé	Risque traité / accepté
P1	Réaliser l'inventaire des actifs et formaliser la gouvernance : propriétaire métier, dépositaire technique, classification, règles de conservation et procédure d'accès.	RSSI, avec les propriétaires métiers et la DSI	Mois 1 à 2	~10000€	Traite le manque de responsabilités et de règles. Pendant l'inventaire, le risque accepté est que certains actifs secondaires restent temporairement mal classés.
P1	Sécuriser les ordinateurs et les sorties de données : chiffrement complet des postes, MDM, effacement à distance, MFA, blocage des transferts vers les messageries personnelles et contrôle des exports CRM. Ajouter une sensibilisation courte des salariés.	DSI et RSSI, avec la DRH et la direction commerciale	Mois 1 à 3	~27000€	Traite la perte du portable RH et l'export des prospects. Le déploiement d'une DLP avancée sur tous les SaaS est différé : un risque résiduel de fuite par un canal non couvert reste accepté.

Priorité	Action	Responsable	Échéance	Coût estimé	Risque traité / accepté
P1	Renforcer la disponibilité de PayFlow avant la migration : environnement de préproduction, procédure de changement, déploiement progressif avec retour arrière, redondance, sauvegardes et test du plan de reprise. Les accès d'urgence restent possibles mais sont nominatifs et tracés.	Direction technique et DSI, sous l'autorité de la direction produit	Mois 1 à 6	~40000 €	Traite le risque d'interruption des encaissements et remboursements. Une architecture active-active sur plusieurs régions est différée pour des raisons de coût : une panne cloud exceptionnelle peut donc encore provoquer une indisponibilité limitée.
P2	Protéger les journaux d'audit : durée de conservation validée, stockage séparé et non modifiable, droits d'administration limités, alertes SIEM et contrôle mensuel de la collecte.	RSSI et équipe SOC-SIEM	Mois 2 à 6	~18000€	Traite la suppression accidentelle des journaux et la perte de traçabilité. Un SOC externalisé fonctionnant 24h/24 est différé : la détection hors horaires ouvrés pourra être plus lente, sauf pour les alertes critiques transmises à l'astreinte.
P2	Sécuriser le cycle de vie cloud : hébergement dans l'UE, clauses contractuelles de restitution et de suppression, rotation des clés KMS, séparation des rôles, destruction cryptographique et environnement de test utilisant des données masquées ou synthétiques.	RSSI et DSI, avec les directions juridique et produit	Mois 3 à 9	~20 000 €	Traite la maîtrise des clés, des SSD cloud et des données de test. La destruction physique individualisée des SSD n'étant pas garantie, Paynora accepte ce risque résiduel sous réserve de la destruction des clés et d'une attestation contractuelle du fournisseur.

Budget total estimé : 115 000 € sur 120 000 €.

La marge restante de **5 000 €** est conservée pour les imprévus de migration, les licences supplémentaires ou une action corrective révélée par l'inventaire.

Actions P3 différées

Certaines mesures ne sont pas retenues dans le budget de cette première année :

- mise en place d'un SOC complet disponible 24h/24 et 7j/7 ;
- déploiement d'une solution DLP avancée sur l'ensemble des applications SaaS ;
- architecture PayFlow active-active sur plusieurs régions européennes.

Ces mesures améliorent la détection et la disponibilité, mais leur coût serait disproportionné pour une PME de 92 salariés dans l'immédiat. Le risque est temporairement accepté par la direction et réduit grâce aux alertes critiques avec astreinte, au blocage des transferts les plus dangereux, aux sauvegardes testées et aux

procédures de retour arrière. Leur financement devra être réévalué lors de la revue annuelle ou après un incident important.

- **Concluez le dossier par une synthèse d'une page à destination du comité : diagnostic, trois risques majeurs, plan d'action et décision demandé**

Diagnostic

La majorité des actifs essentiels de Paynora sont classés N4 – Critique. Les incidents constatés montrent un manque de gouvernance, de contrôle des données et de préparation aux interruptions de service.

Trois risques majeurs

Indisponibilité de PayFlow, empêchant les commerçants d'encaisser leurs clients.

Fuite de données sensibles, notamment depuis un ordinateur perdu ou un export non autorisé.

Perte de traçabilité, liée à la suppression des journaux ou à une mauvaise gestion du cloud.

Plan proposé

Paynora doit définir les propriétaires de chaque actif, sécuriser les postes et les transferts, renforcer la disponibilité de PayFlow et protéger les journaux. La migration devra rester dans l'Union européenne et prévoir la destruction cryptographique des données.

Décision demandée

Le comité doit approuver le budget de 115 000 €, nommer les propriétaires métiers et demander un suivi trimestriel au RSSI. Il devra également accepter temporairement les risques liés aux mesures P3 reportées.

Critères d'évaluation

Critère	Points
Qualité de la classification et raisonnement C-I-D	6
Pertinence des contrôles et du cycle de vie	5
Compréhension des rôles et de la gouvernance	5
Priorisation et prise en compte du métier	4

Règle de notation : réponses alternatives acceptées si elles sont cohérentes et justifiées. Notation sur 20 points.